SILENT. SWIFT. SECURE.

PENETRATION TEST REPORT

Internal Network & Active Directory Security Assessment

Client	[CLIENT COMPANY NAME]
Engagement	Internal Network Penetration Test
Environment	BLACKBYTE.local domain (lab reference environment)
Assessment dates	[DD Mon YYYY] – [DD Mon YYYY]
Report version	1.0
Classification	CONFIDENTIAL
Prepared by	[Lead Consultant Name], Black Byt3

contact@blackbyt3.com · www.blackbyt3.com · [+92 3XX XXXXXXX]

i. Document Control & Confidentiality

Document title	PENETRATION TEST REPORT — Internal Network & Active Directory Security Assessment
Client	[CLIENT COMPANY NAME]
Classification	CONFIDENTIAL
Version	1.0
Prepared by	[Lead Consultant Name], Black Byt3
Reviewed by	[Reviewer Name], Black Byt3
Provider	Black Byt3 · contact@blackbyt3.com · www.blackbyt3.com

Confidentiality notice. This report contains sensitive security information about [CLIENT COMPANY NAME] and is classified CONFIDENTIAL. It is intended solely for authorized recipients. Do not distribute, copy, or store it outside approved channels. Findings describe issues present during the testing window only.

Contents

Right-click and choose 'Update Field' to build the table of contents.

1. Executive Summary

The assessment identified that a low-privileged domain user could achieve full compromise of the Active Directory domain in a short time. Due to a weak service-account password combined with excessive privileges, an attacker starting from a single standard user account was able to obtain Domain Administrator rights, giving complete control over every user, system, and data asset in the environment. The overall risk is therefore rated CRITICAL and immediate remediation is recommended.

Overall Risk Rating

CRITICAL

Findings by Severity

Severity	Count
Critical	1
High	2
Medium	2
Low	1
Informational	1

Key Recommendations

- Reset all service-account passwords to long (25+ character) random values, or migrate to Group Managed Service Accounts (gMSA) that rotate automatically.
- Remove Domain Admin and other excessive privileges from service accounts; apply least-privilege and a tiered administration model.
- Disable LLMNR and NBT-NS via Group Policy and enforce SMB signing to prevent credential interception and relay attacks.
- Enforce a strong password policy and screen against known-breached passwords.
- Establish a regular patching cycle and disable unused legacy protocols (including IPv6 where not required).

2. Scope & Rules of Engagement

In Scope

- Internal Active Directory domain: BLACKBYTE.local
- Domain Controller: BLACKBYTE-DC (192.168.60.136)
- Domain-joined workstation: DESKTOP-3I331MB (192.168.60.131)
- Internal network segment: 192.168.60.0/24

Out of Scope

- Any host or network outside the ranges listed above
- Denial-of-Service (DoS) testing
- Social engineering / phishing of staff (unless separately authorized)
- Physical security testing

Rules of Engagement

Item	Detail
Authorization	Testing performed under signed written authorization from the client.
Testing window	Agreed engagement dates and hours as stated on the cover page.
Approach	Grey-box: a single standard domain user credential was provided to simulate an assumed-breach / malicious-insider scenario.
Emergency contact	A client point of contact was available throughout for critical findings.
Data handling	All captured data and evidence are stored securely and shared only with authorized client personnel.

3. Assessment Methodology

1. Reconnaissance & Enumeration

Mapped the internal network and enumerated the Active Directory domain, users, groups, computers, and service accounts.

2. Credential Access

Attempted name-resolution poisoning and Kerberos-based attacks to obtain and crack credentials.

3. Privilege Escalation & Lateral Movement

Used recovered credentials to move laterally and escalate toward Domain Administrator.

4. Post-Exploitation

Demonstrated impact of domain compromise (credential extraction) without disrupting operations.

5. Reporting

Documented all findings with evidence, business impact, and prioritized remediation. Methodology aligned with PTES and the MITRE ATT&CK framework.

4. Findings Summary

ID	Finding	Severity	CVSS
BB3-01	Kerberoastable Service Account with Weak Password Leads to Full Domain Compromise	**Critical**	9.0
BB3-02	LLMNR / NBT-NS Poisoning Permits Credential Interception	**High**	8.1
BB3-03	SMB Signing Not Enforced Enables NTLM Relay	**High**	7.5
BB3-04	Weak and Guessable Account Passwords	**Medium**	6.5
BB3-05	Service Account Granted Excessive (Domain Admin) Privileges	**Medium**	6.4
BB3-06	Unnecessary IPv6 and Legacy Name Resolution Increase Attack Surface	**Low**	4.3
BB3-07	Missing Security Baseline, Patch and Hardening Gaps	**Informational**	N/A

5. Detailed Findings

BB3-01 Kerberoastable Service Account with Weak Password Leads to Full Domain Compromise

CRITICAL · CVSS 9.0

Affected: Domain: BLACKBYTE.local · Account: sservice · DC: BLACKBYTE-DC (192.168.60.136)

DESCRIPTION

The domain service account 'sservice' has a Service Principal Name (SPN) registered, making it 'Kerberoastable'. Any authenticated domain user can request a Kerberos service ticket for the account and crack it offline. The account's password was weak and was recovered within seconds using a standard wordlist.

BUSINESS IMPACT

Starting from a single low-privileged user, an attacker recovered the service-account password, which also held Domain Administrator rights. This grants complete control of the domain — every account, system, and all data — and is equivalent to total compromise of the organization.

EVIDENCE / REPRODUCTION STEPS

1. `Authenticated as a standard domain user (bilal).`
2. `Requested service tickets: impacket-GetUserSPNs BLACKBYTE.local/bilal -dc-ip 192.168.60.136 -request`
3. `Cracked the ticket offline: hashcat -m 13100 kerb.txt rockyou.txt → password recovered`
4. `Confirmed Domain Admin access: netexec smb 192.168.60.136 -u sservice -p <password> → (Pwn3d!)`

REMEDIATION

Set a long (25+ character) random password for all service accounts, or migrate to Group Managed Service Accounts (gMSA). Remove Domain Admin rights from service accounts (least privilege). Monitor Kerberos service-ticket requests (Event ID 4769) for anomalies.

REFERENCES

MITRE ATT&CK T1558.003 (Kerberoasting); Microsoft gMSA documentation.

BB3-02 LLMNR / NBT-NS Poisoning Permits Credential Interception

HIGH · CVSS 8.1

Affected: Internal segment 192.168.60.0/24 (all Windows hosts)

DESCRIPTION

Legacy name-resolution protocols LLMNR and NBT-NS are enabled. When name resolution fails, hosts broadcast requests that an attacker on the same segment can answer, causing victims to send their NTLMv2 authentication hashes to the attacker.

BUSINESS IMPACT

An attacker can passively harvest domain credential hashes and crack them offline or relay them to other systems, providing an initial foothold and enabling lateral movement.

EVIDENCE / REPRODUCTION STEPS

5. `Ran Responder on the internal segment to answer poisoned name requests.`
6. `Captured NTLMv2 authentication hashes from responding hosts.`
7. `Cracked recovered hashes offline with hashcat / a wordlist.`

REMEDIATION

Disable LLMNR via Group Policy ('Turn off multicast name resolution') and disable NBT-NS on all adapters. Where broadcast resolution is genuinely required, isolate and monitor it. Enforce SMB signing (see BB3-03).

REFERENCES

MITRE ATT&CK T1557.001; Microsoft LLMNR/NBT-NS hardening guidance.

BB3-03 SMB Signing Not Enforced Enables NTLM Relay

HIGH · CVSS 7.5

Affected: Domain hosts where SMB signing is not required

DESCRIPTION

Several hosts do not require SMB signing. Combined with the name-resolution weakness above, captured authentication can be relayed to these hosts instead of being cracked, authenticating the attacker as the victim.

BUSINESS IMPACT

Where the relayed user holds local administrator rights on the target, the attacker gains administrative access and can dump credentials or execute commands — without ever cracking a password.

EVIDENCE / REPRODUCTION STEPS

8. `Identified hosts without SMB signing (signing:False) via network scanning.`
9. `Combined name-resolution poisoning with an NTLM relay tool (ntlmrelayx).`
10. `Relayed captured authentication to a host to obtain administrative access.`

REMEDIATION

Enforce SMB signing (require) via Group Policy on all servers and workstations. Reduce local administrator sprawl (deploy LAPS) and prefer Kerberos over NTLM.

REFERENCES

MITRE ATT&CK T1557; Microsoft SMB signing guidance.

BB3-04 Weak and Guessable Account Passwords

MEDIUM · CVSS 6.5

Affected: Multiple domain accounts

DESCRIPTION

Several domain accounts, including a privileged service account, used weak or dictionary-based passwords that were recovered quickly during offline cracking.

BUSINESS IMPACT

Weak passwords dramatically lower the effort required for credential attacks and were the key enabler of the critical domain-compromise finding.

EVIDENCE / REPRODUCTION STEPS

11. `Recovered password hashes via the Kerberoasting and poisoning findings.`
12. `Cracked multiple passwords within minutes using a standard wordlist.`

REMEDIATION

Enforce a strong password policy (length over complexity), screen against known-breached password lists, and require especially strong passphrases for privileged and service accounts.

REFERENCES

NIST SP 800-63B; MITRE ATT&CK T1110 (Brute Force).

BB3-05 Service Account Granted Excessive (Domain Admin) Privileges

MEDIUM · CVSS 6.4

Affected: Account: sservice (member of Domain Admins)

DESCRIPTION

A service account was a member of the Domain Admins group. Service accounts rarely need such broad rights, and this violated least-privilege principles.

BUSINESS IMPACT

The excessive privilege turned a single cracked service-account password into full domain compromise. Without Domain Admin rights, the same weak password would have had far lower impact.

EVIDENCE / REPRODUCTION STEPS

13. `Enumerated group memberships during Active Directory reconnaissance.`
14. `Confirmed the service account's membership in a highly privileged group.`

REMEDIATION

Apply least privilege: grant service accounts only the specific rights they require. Adopt a tiered administration model that separates Tier-0 (domain) assets from everyday accounts.

REFERENCES

Microsoft Tiered Administration / Privileged Access model.

BB3-06 Unnecessary IPv6 and Legacy Name Resolution Increase Attack Surface

LOW · CVSS 4.3

Affected: Internal segment 192.168.60.0/24

DESCRIPTION

IPv6 is enabled but unused, and legacy name resolution remains active. Rogue IPv6 / DHCPv6 techniques (e.g. mitm6) can position an attacker as a victim's DNS server and enable further relay attacks.

BUSINESS IMPACT

Expands the attack surface and provides an alternative path to intercept authentication and escalate within the domain.

EVIDENCE / REPRODUCTION STEPS

15. `Observed clients requesting DHCPv6 configuration on the segment.`
16. `Noted potential for rogue DHCPv6/DNS positioning to support relay attacks.`

REMEDIATION

Where IPv6 is not used, block rogue DHCPv6 and Router Advertisements at the switch (RA Guard / DHCPv6 Guard). Enable LDAP signing and channel binding on Domain Controllers to resist relay to LDAP.

REFERENCES

MITRE ATT&CK T1557; Microsoft LDAP channel binding guidance.

BB3-07 Missing Security Baseline, Patch and Hardening Gaps

INFORMATIONAL · CVSS N/A

Affected: Domain-wide

DESCRIPTION

General hardening opportunities were observed, including monitoring/alerting gaps and the absence of a consistently applied security baseline. No specific unpatched critical vulnerability was confirmed in scope, but a formal patch and hardening program is recommended.

BUSINESS IMPACT

Reduces the organization's ability to detect and resist the attack techniques demonstrated in this report.

EVIDENCE / REPRODUCTION STEPS

17. `Observed limited alerting on credential-access and reconnaissance activity during testing.`

REMEDIATION

Adopt CIS Benchmarks / Microsoft Security Baselines, implement centralized logging (SIEM) with alerting on the ATT&CK techniques above, and maintain a regular patch-management cycle.

REFERENCES

CIS Benchmarks; Microsoft Security Baselines; MITRE ATT&CK.

6. Remediation Roadmap

Immediate (0–7 days)

- Reset the sservice password to a long random value and remove it from Domain Admins.
- Reset any other accounts identified with weak passwords.

Short term (1–4 weeks)

- Disable LLMNR/NBT-NS via GPO and enforce SMB signing domain-wide.
- Deploy LAPS to eliminate shared local administrator passwords.

Medium term (1–3 months)

- Migrate service accounts to gMSA and implement a tiered administration model.
- Enforce a breached-password-screened strong password policy.

Ongoing

- Establish centralized logging/alerting (SIEM) and a regular patch cycle.
- Block unused IPv6 (RA/DHCPv6 Guard); enable LDAP signing + channel binding.
- Repeat penetration testing after remediation to validate fixes.

7. Conclusion

The environment is currently exposed to a critical risk: a standard domain user can reach Domain Administrator through a weak, over-privileged service account, aided by legacy protocols that leak and relay credentials. Encouragingly, the highest-impact issues are inexpensive to fix — strong service-account passwords, least-privilege, disabling LLMNR/NBT-NS, and enforcing SMB signing would remove the demonstrated attack path. Black Byt3 recommends implementing the immediate and short-term actions without delay and scheduling a re-test to confirm remediation.

8. Appendices

Appendix A — Severity Rating Definitions

Rating	Definition
Critical	Trivial path to full compromise of the environment or highly sensitive data; fix immediately.
High	Significant risk that could lead to compromise of systems or data; prioritize remediation.
Medium	Moderate risk, often requiring specific conditions or chaining with other issues.
Low	Limited risk; good-practice hardening that reduces attack surface.
Informational	No direct risk; observations and recommendations to improve overall posture.

Appendix B — Tools Used

- Nmap
- NetExec (CrackMapExec)
- Responder
- Impacket suite (GetUserSPNs, secretsdump, ntlmrelayx)
- Hashcat
- BloodHound
- Evil-WinRM

Appendix C — References

PTES (Penetration Testing Execution Standard); MITRE ATT&CK Framework; OWASP Testing Guide; CIS Benchmarks & Microsoft Security Baselines. Per-finding references are listed with each finding above.